# Security review — Marketing25 pharmacy poster platform

Date: 3 October 2026 · Scope: web app (Next.js BFF), .NET API, ai-service (FastAPI), Dockerfiles, deployment script and configuration in the repository · Type: static source and configuration review

## Summary

The application's core security design is sound: passwords, tokens and sessions are handled well, admin areas are consistently protected and tested, and tenant isolation is covered by automated tests. The most important problems are in a few specific places rather than the architecture: the poster renderer will fetch any URL or stored file a user puts in a design (SEC-01, SEC-02), anonymous authentication endpoints have no rate limits (SEC-05), share-by-email can be abused to send mail from your domain (SEC-06), and two secrets are handled unsafely in configuration (SEC-03, SEC-04).

| Severity | Count | Meaning |
|---|---|---|
| **High** | 6 | Exploitable by any signed-up user or anonymously; fix before wider launch |
| **Medium** | 5 | Real risk with conditions or limited impact; plan in the next cycle |
| **Low** | 5 | Hardening; schedule |
| **Info** | 2 | No action needed now / process |

## Remediation update

Fixes were made the same day. **Fixed:** SEC-01, SEC-02, SEC-03, SEC-04, SEC-05, SEC-06, SEC-07, SEC-08, SEC-10, SEC-11, SEC-14, SEC-15, SEC-17. **Partly fixed:** SEC-09, SEC-12, SEC-13, SEC-16. **No action:** SEC-18. Each finding below ends with its status. Every High finding is fixed; of the Mediums, only SEC-09's script-src policy remains. Tests: Acme.Tests/Security/SecurityReviewFixTests, Acme.IntegrationTests/SecurityReviewTests and apps/ai-service/tests/test_security_review.py; `pnpm test:prove -- SEC` re-introduces each fix's bug and checks a test fails. Deploy notes: PRODUCTION_CHECKLIST.md §0 — in particular, the API will not start in production without a real Jwt__Secret.

## Findings at a glance

| ID | Severity | Finding | Status |
|---|---|---|---|
| SEC-01 | **High** | Server-side request forgery in poster export | **Fixed** |
| SEC-02 | **High** | Another tenant's stored files can be drawn into your poster | **Fixed** |
| SEC-03 | **High** | Mailjet API key and secret committed to the repository | **Fixed** |
| SEC-04 | **High** | JWT signing secret falls back to a public placeholder | **Fixed** |
| SEC-05 | **High** | No rate limiting on sign-in, password reset, sign-up or screen pairing | **Fixed** |
| SEC-06 | **High** | Share-by-email can be used as an open mail relay | **Fixed** |
| SEC-07 | **Medium** | Unbounded image cache in the exporter (memory exhaustion) | **Fixed** |
| SEC-08 | **Medium** | Unmetered AI endpoints reachable by any signed-in user | **Fixed** |
| SEC-09 | **Medium** | Missing browser security headers | **Partly fixed** |
| SEC-10 | **Medium** | SVG logos are accepted and served from the app's own origin | **Fixed** |
| SEC-11 | **Medium** | Anonymous configuration endpoint in production | **Fixed** |
| SEC-12 | **Low** | Account enumeration | **Partly fixed** |
| SEC-13 | **Low** | Weak password policy and unverified accounts | **Partly fixed** |
| SEC-14 | **Low** | Containers run as root | **Fixed** |

| ID | Severity | Finding | Status |
|---|---|---|---|
| SEC-15 | Low | Pharmacy uploads stored in the public template-asset area | Fixed |
| SEC-16 | Low | Repository hygiene | Partly fixed |
| SEC-17 | Info | Provider error text returned to callers | Fixed |
| SEC-18 | Info | Dependency status | No action |

## Recommended order of work (as reviewed)

**1. Before wider launch:** SEC-01 and SEC-02 (one change: restrict renderer image sources), SEC-04 (fail-fast secret check), SEC-05 (rate limits), SEC-06 (cap share-by-email).

**2. Next:** SEC-03 (rotate and move the Mailjet key — currently an accepted risk), SEC-07, SEC-08, SEC-09, SEC-10, SEC-11.

**3. Hardening:** SEC-12 to SEC-16; add dependency scanning to CI (SEC-18).

## Detailed findings

| SEC-01 | Server-side request forgery in poster export | High |
|---|---|---|
| **Where** | `apps/api/src/Acme.Infrastructure/Export/QuestPdfExporter.cs:534-543 (LoadImageAsync)` | |
| **Issue** | When a poster is rendered (PDF/PNG export, campaign email image, share-by-email, display screens), every image shape whose `blobKey` starts with http:// or https:// is fetched by the API with a plain HttpClient. The canvas is saved by the pharmacy through PUT /api/posters/{id} and no rule restricts image sources, so any signed-up user controls the URL. There is no host allow-list, redirects are followed, there is no response size limit and private address ranges are not blocked. | |
| **Impact** | An attacker can make the API call internal services (ai-service on the container network, Azure instance metadata/identity endpoints, internal admin ports) and scan the internal network. Responses that decode as images are returned inside the exported PDF/PNG, so it is partially a full-read SSRF; large downloads also tie up the API (see SEC-07). | |
| **Recommendation** | Only render images from our own sources: template assets (/api/assets/templates/...), the brand paths, the caller's own blob keys, and data: URIs. Reject any other http(s) source when the canvas is saved and again at render. If an external host is ever needed, use an explicit host allow-list, resolve and refuse private/link-local/loopback addresses, disable redirects, and cap the response size. | |
| **Status** | **Fixed.** New CanvasImageSources allow-list: own template assets, the brand logo/QR routes, data:image (png/jpeg/webp/gif) and https://images.unsplash.com only. Enforced when posters and templates are saved, and again at render (disallowed sources are blanked). The exporter fetches only allow-listed https on the default port, with redirects off and a 12 MB cap. | |

| SEC-02 | Another tenant's stored files can be drawn into your poster | High |
|---|---|---|
| **Where** | `apps/api/src/Acme.Infrastructure/Export/QuestPdfExporter.cs:557-564` | |
| **Issue** | Any image key that is not a URL, data URI or template asset is downloaded straight from blob storage with no ownership check. The video pipeline already guards this case (VideoImagePolicy only accepts keys under the owner's own prefixes); the poster renderer does not. | |
| **Impact** | A pharmacy that learns another pharmacy's blob key (logos, poster renders, video attachments; keys follow brand/logos/{ownerId}/{guid}, videos/{ownerId}/..., posters/{ownerId}/...) can render that file into its own export. Isolation currently rests on the keys being unguessable, not on an access check. | |
| **Recommendation** | At render time accept raw blob keys only when they start with the poster owner's prefixes (the same rule as VideoImagePolicy.WhyKeyRefused), and reject foreign keys when a canvas is saved. | |
| **Status** | **Fixed.** Raw storage keys are refused at save and blanked at render; the exporter reads raw keys only under brand/logos/ (no traversal), which the render reaches only through the caller's own brand routes. | |

| SEC-03 | Mailjet API key and secret committed to the repository | High |
|---|---|---|
| **Where** | `apps/api/src/Acme.WebApi/appsettings.json:89-90 (inherited by Production)` | |
| **Issue** | The Mailjet ApiKey/SecretKey are in source control and appsettings.Production.json does not override them, so production sends with the committed credentials. Note: keeping them in place was an earlier explicit decision; it is recorded here as an accepted risk, not changed. | |
| **Impact** | Anyone with read access to the repository (or a leaked image/clone) can send email as info@sonarinformatics.com / the configured sender, read account stats, and damage the domain's sending reputation. | |
| **Recommendation** | Rotate the key pair in Mailjet, move it to App Service settings / Key Vault (Messaging__Mailjet__ApiKey, ...SecretKey), blank the values in appsettings.json, and purge them from git history if the repository is ever shared more widely. | |
| **Status** | **Fixed.** Rotated in production on 3 October 2026; production reads the keys from App Service settings. appsettings.json, which production also loads, holds no credentials. The previous keys remain in appsettings.Development.json as development-only credentials, which is never loaded outside Development. | |

| SEC-04 | JWT signing secret falls back to a public placeholder | High |
|---|---|---|
| **Where** | `apps/api/src/Acme.WebApi/appsettings.json:16; Program.cs:88` | |
| **Issue** | The base configuration contains Jwt:Secret = "REPLACE_ME_IN_DEVELOPMENT_USER_SECRETS_OR_KEYVAULT" (51 characters, long enough to be accepted). Nothing at startup refuses it, so a deployment that is missing Jwt__Secret starts normally and signs tokens with a value printed in the repository. The same secret also signs the poster-image and video-download links and the ai-service quota assertions. | |
| **Impact** | If the environment variable is ever missing (new slot, renamed setting), anyone can mint a SuperAdmin token and forge download links. The failure is silent. | |
| **Recommendation** | Fail fast outside Development when the secret is missing, equals the placeholder, or is shorter than 32 random bytes; log only the fingerprint (already done). Consider separate secrets for JWTs and for signed links. | |
| **Status** | **Fixed.** JwtSecretPolicy: outside Development the API refuses to start when the secret is missing, under 32 bytes, or a placeholder; Development logs a warning. | |

| SEC-05 | No rate limiting on sign-in, password reset, sign-up or screen pairing | High |
|---|---|---|
| **Where** | `AuthController (login, register, forgot-password, reset-password), DisplayKioskController (claim); Program.cs registers only the stock-search limiter` | |
| **Issue** | Anonymous authentication endpoints accept unlimited requests and accounts are never locked. forgot-password sends an email per request. Screen pairing codes are 6 characters from a 23-letter alphabet (about 148 million values) with no attempt limit. | |
| **Impact** | Credential stuffing and password spraying against pharmacy and staff accounts (passwords may be as short as 8 characters); mail-bombing any address through forgot-password; with sustained guessing, hijacking a pairing code during its window. | |
| **Recommendation** | Add ASP.NET rate-limit policies (per IP and per target account) on login, register, forgot/reset password, verify, invitation accept and display claim; add progressive delay or temporary lockout after repeated failures; alert on spikes (the new audit log already records auth.login.failed). | |
| **Status** | **Fixed.** Per-address limits on sign-in, sign-up, reset, verification, invitation acceptance, forgot-password/resend and screen pairing (429 with Retry-After, configurable under RateLimits:*). Per-account lock after 8 wrong passwords for 15 minutes. Unknown addresses are checked against a dummy hash so timing does not reveal them. | |

| SEC-06 | Share-by-email can be used as an open mail relay | High |
|---|---|---|
| **Where** | `apps/api/src/Acme.WebApi/Controllers/PosterExportController.cs:120-190 (POST /api/posters/{id}/share-email)` | |
| **Issue** | Any signed-in account (sign-up is open and email verification is not required) can send a poster with a free-text subject and message to any number of addresses, from the company's sending domain. There is no recipient cap, no rate limit and no plan gate. | |
| **Impact** | Spam and phishing sent from a trusted domain; domain/IP reputation damage that would also stop real campaign and password-reset mail being delivered; Mailjet account suspension. | |
| **Recommendation** | Cap recipients per send (e.g. 10) and per day per account, require a verified email address, rate-limit the endpoint, and consider plan-gating or fixing the subject line. | |
| **Status** | **Fixed.** Share-by-email: at most 10 recipients, 10 sends an hour per person, subject and message length caps, and no links in the subject or message. | |

| SEC-07 | Unbounded image cache in the exporter (memory exhaustion) | Medium |
|---|---|---|
| **Where** | `apps/api/src/Acme.Infrastructure/Export/QuestPdfExporter.cs:35` | |
| **Issue** | A static ConcurrentDictionary caches every fetched image's bytes, keyed by URL/key, for the life of the process and is never evicted. | |
| **Impact** | Combined with SEC-01, rendering posters that point at many distinct or very large URLs grows API memory until the process is killed — a cheap denial of service. | |
| **Recommendation** | Replace with a size-limited MemoryCache (SizeLimit, sliding expiry) and cap each entry's size. | |
| **Status** | **Fixed.** Exporter image cache is a size-limited MemoryCache (96 MB, 30-minute sliding expiry) and each image is capped at 12 MB. | |

| SEC-08 | Unmetered AI endpoints reachable by any signed-in user | Medium |
|---|---|---|
| **Where** | `apps/ai-service/app/routers/canvas.py (/api/canvas/suggest), routers/video.py (/api/video/classify-refine)` | |
| **Issue** | ai-service is internet-reachable and these endpoints require only a valid JWT, not the API's quota assertion. Any pharmacy can call them directly in a loop. FastAPI's /docs and /openapi.json are also public and list every route. | |
| **Impact** | Uncapped model spend (Anthropic) attributable to no allowance; route discovery. | |
| **Recommendation** | Require the quota assertion (or staff) as generate-template already does, add a per-user rate limit, and disable docs in production (docs_url=None, openapi_url=None) or restrict ai-service ingress to the API. | |
| **Status** | **Fixed.** ai-service: /api/canvas/suggest is staff-only; /api/video/classify-refine has a per-user limit (20 a minute, staff exempt); /docs and /redoc are off unless APP_ENV=development. | |

| SEC-09 | Missing browser security headers | Medium |
|---|---|---|
| **Where** | `apps/web/next.config.mjs, apps/web/src/middleware.ts, apps/api Program.cs` | |
| **Issue** | Neither the web app nor the API sets Content-Security-Policy, frame-ancestors / X-Frame-Options, Strict-Transport-Security, X-Content-Type-Options or Referrer-Policy. | |
| **Impact** | The admin console can be framed (clickjacking of actions such as role changes or deactivation); no CSP backstop if an XSS is ever introduced; MIME sniffing of user-supplied files. | |
| **Recommendation** | Add headers() in next.config (CSP with frame-ancestors 'none', HSTS, nosniff, Referrer-Policy strict-origin-when-cross-origin) and UseHsts plus a small header middleware in the API. | |
| **Status** | **Partly fixed.** Web: CSP (frame-ancestors, base-uri, object-src, form-action), X-Frame-Options, nosniff, Referrer-Policy, HSTS, Permissions-Policy; x-powered-by removed. API: default-src 'none' CSP, nosniff, X-Frame-Options, no-referrer, HSTS outside Development. Open: a script-src policy needs per-request nonces in Next.js middleware. | |

| SEC-10 | SVG logos are accepted and served from the app's own origin | Medium |
|---|---|---|
| **Where** | `apps/api/src/Acme.WebApi/Controllers/BrandKitController.cs:19-23, 166 (upload); GET /api/brand-kit/logo via the web BFF` | |
| **Issue** | image/svg+xml is an allowed logo type, the type is taken from the browser's header (not the file's bytes), and the file is returned with its stored content type through the web app's domain. | |
| **Impact** | An SVG containing script executes in the web origin when the logo URL is opened directly — for example by a staff member managing that pharmacy — giving the attacker that session's privileges. Rendering inside the editor (as an image) is safe. | |
| **Recommendation** | Rasterise SVG logos to PNG on upload (Svg.Skia is already a dependency) or strip scripts; sniff all uploads by their bytes (as the new photo upload does); serve user files with X-Content-Type-Options: nosniff and Content-Security-Policy: sandbox. | |
| **Status** | **Fixed.** Logos are stored by what their bytes are. SVGs are drawn to PNG at upload, and an SVG with an external href, CSS url()/@import or DTD entity is refused before parsing. Legacy SVG logos are served with a sandboxed, script-free CSP. | |

| SEC-11 | Anonymous configuration endpoint in production | Medium |
|---|---|---|
| **Where** | `apps/api/src/Acme.WebApi/Controllers/DiagnosticsController.cs:58 (GET /api/diagnostics/config)` | |
| **Issue** | The controller is [AllowAnonymous]; /jwt is limited to Development but /config is not. | |
| **Impact** | Reveals the environment name, the Azure storage account name, the CORS origin and whether messaging and Sonar are mocked — useful reconnaissance. | |
| **Recommendation** | Return 404 outside Development, or move it behind the SuperAdmin policy like the email diagnostics. | |
| **Status** | **Fixed.** /api/diagnostics/config answers only in Development or to a SuperAdmin; 404 otherwise. | |

| SEC-12 | Account enumeration | Low |
|---|---|---|
| **Where** | `AuthService.RegisterAsync ("Email is already registered."); LoginAsync timing` | |
| **Issue** | Registration says when an address already has an account, and login returns faster for unknown addresses because no password hash is checked. | |
| **Impact** | Confirms which pharmacies and staff have accounts — useful for targeted phishing and stuffing. | |
| **Recommendation** | Answer registration uniformly ("check your email") and verify against a dummy hash when the user is unknown. Forgot-password is already uniform. | |
| **Status** | **Partly fixed.** Sign-in timing no longer differs for unknown addresses. Sign-up still says an address is registered: a uniform answer needs an email-first sign-up flow. The per-address limit bounds probing meanwhile. | |

| SEC-13 | Weak password policy and unverified accounts | Low |
|---|---|---|
| **Where** | `AuthService.RegisterAsync, AccountEmailService` | |
| **Issue** | Passwords need only 8 characters with no breached-password check, and a verified email is not required before using sending features. | |
| **Impact** | Raises the success rate of SEC-05 and enables SEC-06. | |
| **Recommendation** | 12+ characters or a breached-password (k-anonymity) check; require verification before share-email, campaigns and invitations; offer MFA for staff accounts. | |
| **Status** | **Partly fixed.** New passwords need 12+ characters (72-byte BCrypt ceiling enforced) and common passwords are refused, in the API and the forms. Open: verified email before sending features; MFA for staff. | |

| SEC-14 | Containers run as root | Low |
|---|---|---|
| **Where** | `apps/api/Dockerfile, apps/web/Dockerfile, apps/ai-service/Dockerfile` | |
| **Issue** | No USER directive; all three processes run as root inside their containers. | |
| **Impact** | Any code-execution bug becomes root in the container, easing escape or tampering. | |
| **Recommendation** | Add a non-root user (the aspnet and node images ship app/node users) and drop write access outside the working directories. | |
| **Status** | **Fixed.** API runs as the image's app user, web as node, ai-service as a new app user (the entrypoint fixes ownership of an old media volume, then drops privileges). | |

| SEC-15 | Pharmacy uploads stored in the public template-asset area | Low |
|---|---|---|
| **Where** | `PosterPhotoService / TemplateAssetService (/api/assets/templates/{guid}, anonymous)` | |
| **Issue** | Photos a pharmacy uploads for AI designs are served anonymously by an unguessable 128-bit name, like gallery images. | |
| **Impact** | Not enumerable, but anyone given a link can view the photo indefinitely, and unused uploads are never deleted. | |
| **Recommendation** | Store pharmacy uploads under the owner's prefix and serve them through an authenticated or signed route; add a clean-up for unused uploads. | |
| **Status** | **Fixed.** Pharmacy uploads go to a private owner-prefixed area (pharmacy-photos/{owner}/), are served only to their owner through an authenticated route, are read from the owner's own area when designing, and are deleted after 7 days. Uploads made before this change remain in the asset area under unguessable names. | |

| SEC-16 | Repository hygiene | Low |
|---|---|---|
| **Where** | `playwright-report/, test-results/, .qa*/ (tracked); tests/browser default passwords; docker-compose.yml` | |
| **Issue** | Test reports and screenshots are committed; browser tests default to the dev passwords; local Mongo is published on all interfaces with root/example. | |
| **Impact** | Screenshots may capture data; the dev database is reachable from the local network while compose is running. | |
| **Recommendation** | Ignore and remove the report folders; bind dev ports to 127.0.0.1. | |
| **Status** | **Partly fixed.** Report folders and .qa*/ are git-ignored; local Mongo and Azurite bind to 127.0.0.1 and the app ports default to it (BIND_ADDR to open them). Still to do: git rm -r --cached playwright-report test-results .qa .qa2 .qa3 .qa4. | |

| SEC-17 | Provider error text returned to callers | Info |
|---|---|---|
| **Where** | `apps/ai-service/app/chains/template_designer.py ("The design model rejected the request: {exc}")` | |
| **Issue** | Upstream exception messages are passed to the client. | |
| **Impact** | Can reveal model names, account limits or internal URLs. | |
| **Recommendation** | Log the detail; return a generic message with the request id. | |
| **Status** | **Fixed.** Model, image-service and stock-search errors are logged in full; callers get a generic message (an HTTP status at most). | |

| SEC-18 | Dependency status | Info |
|---|---|---|
| **Where** | `apps/ai-service/uv.lock, *.csproj, apps/web/package.json` | |
| **Issue** | Versions checked by hand (no online advisory database was reachable): Next.js 14.2.35, python-jose 3.5.0, cryptography 47.0.0 and urllib3 2.6.3 include the known fixes; ecdsa 0.19.2 has an unfixed timing issue (CVE-2024-23342) that does not apply because only HS256 is used; .NET packages (JwtBearer 8.0.6, IdentityModel 7.5.1) are past their known advisories. | |
| **Impact** | None identified. | |
| **Recommendation** | Run pnpm audit, dotnet list package --vulnerable and pip-audit in CI so this is checked automatically on every change. | |
| **Status** | **No action.** Recommendation stands: add pnpm audit, dotnet list package --vulnerable and pip-audit to CI. | |

## What is already done well

• Passwords hashed with BCrypt (work factor 12); refresh tokens, password-reset, verification and screen tokens stored only as SHA-256 hashes; refresh-token rotation with reuse detection that revokes the whole family; deactivation blocks refresh.

• Every admin endpoint behind named policies (AdminArea / SuperAdminOnly) and checked again in the service; an automated test enumerates every endpoint for anonymous and pharmacy access.

• Tenant isolation tests for posters, patients, groups and campaigns; signed, expiring, constant-time-verified links for poster images and video downloads.

• Stripe webhooks verified with the signing secret; Stripe secrets not committed.

• Social OAuth tokens encrypted at rest (TokenCipher); OAuth state checked on return.

• Mongo regex searches escaped; CSV exports neutralise formula injection; transactional and campaign emails HTML-encode user values; no dangerouslySetInnerHTML in the web app.

• Cookies are httpOnly, SameSite=Lax and Secure in production; the access token never reaches client JavaScript.

• SuperAdmin seeding refuses weak passwords outside Development and is disabled in production; the smoke account password is refused outside Development.

• The new audit log records sign-ins, refusals, staff impersonation and exports, and never stores passwords, tokens or recipient lists.

• Stock photos fetched only by provider ID (no caller URLs); uploads for AI designs checked by their bytes, size-capped and pixel-capped.

## Method and limits

Reviewed: authentication and session handling, authorisation and tenant isolation, input handling (Mongo queries, CSV, HTML email), file uploads, server-side fetching, signed links, the AI service's authentication and cost controls, web cookies and headers, configuration and secrets in tracked files (pattern scan across all 663 tracked text files), Dockerfiles, and dependency versions.

Not covered: live penetration testing against a running deployment, Azure resource configuration (network rules, Key Vault, storage firewall, App Service settings), the contents of deployed environment variables, and an online CVE database lookup (versions were checked manually). Findings SEC-03 and SEC-04 should be confirmed against the real App Service settings. A dynamic test of SEC-01, SEC-05 and SEC-06 against a staging environment is recommended after fixes.

This report describes the repository as of 3 October 2026, including uncommitted work in the working tree.